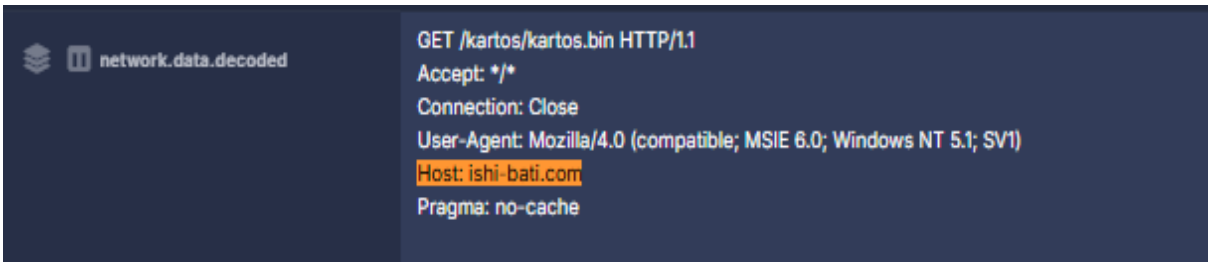
Asunto: [Infección por Malware] - Análisis cronológico de tráfico malicioso en ip-192-168-3-65 (Túnel IPsec)

Resumen del incidente: El día 03/07/2026, los sistemas de inspección y análisis de tráfico perimetral detectaron múltiples anomalías críticas de seguridad originadas desde el host interno 192.168.3.65. Este activo, ubicado en la red remota del cliente, utilizó el túnel de la VPN IPsec hacia nuestro NOC como puente de tránsito para descargar componentes ejecutables maliciosos y realizar transmisiones de comando y control hacia un servidor externo alojado en Países Bajos (IP pública 188.72.243.72, bajo la organización Webzilla B.V.).

Validación: Para aportar máxima certidumbre técnica y documentar de forma irrefutable el comportamiento del vector, el motor de análisis del sistema de detección de intrusos perimetral realizó una reconstrucción cronológica y profunda de los paquetes de datos interceptados en la capa de aplicación (Capa 7 - HTTP). Se determinó que los eventos individuales corresponden a transacciones unificadas analizadas correlativamente.

1. Línea de tiempo de las transacciones HTTP

- **Fase A: Petición de configuración binaria**
    - **Explicación:** En esta fase inicial, el host comprometido establece el primer contacto de red con el servidor externo para descargar directrices operativas. La solicitud se realiza mediante un método GET apuntando al recurso /kartos/kartos.bin. Este archivo .bin funciona como un componente de configuración dinámica que le indica al malware cómo operar, qué dominios alternativos contactar y qué tipo de información local debe recolectar. El sistema perimetral interceptó esta actividad identificando patrones de diseño web exclusivos de botnets conocidas.
    - **Firma IDS 1:** ET MALWARE Zbot Generic URI/Header Struct .bin *(SID: 2018052 / Clase: trojan-activity / Severidad: 1)*
    - **Firma IDS 2:** ET MALWARE Possible Zbot Activity Common Download Struct *(SID: 2017836 / Clase: trojan-activity / Severidad: 1)*
    - **Evidencia de la petición solicitada:**



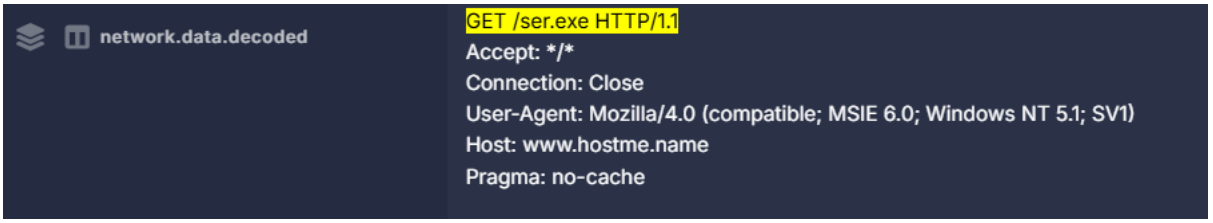
- **Fase B: Transferencia completa del primer ejecutable**
    - **Explicación:** El host solicita el primer binario ejecutable bajo la ruta /kartos/krt.exe. La petición inicial del cliente activó alertas por la estructura hostil de su URL. El servidor malicioso responde con un estado 200 OK entregando un flujo binario de 119,296 bytes (application/x-msdownload). Este componente actúa como un *Dropper* o instalador compactado. El análisis de los paquetes reveló que el archivo viaja empaquetado para evadir firmas tradicionales y contiene llamadas a funciones críticas para asegurar la infección local, tales como inyección de procesos en memoria (WriteProcessMemory) y auto-reconocimiento de entornos de análisis (IsDebuggerPresent), diseñados para apagar el malware si nota que está siendo escaneado por herramientas de seguridad.
    - **Firma 1:** ET MALWARE Terse alphanumeric executable downloader high likelihood of being hostile *(SID: 2019714 / Clase: bad-unknown)*
    - **Firma 2:** ET INFO PE EXE or DLL Windows file download HTTP *(SID: 2018959 / Clase: policy-violation)*
    - **Firma 3:** ET INFO Packed Executable Download *(SID: 2014819 / Clase: misc-activity)*
    - **Firma 4:** ET HUNTING Suspicious Windows Executable WriteProcessMemory *(SID: 2015588 / Clase: misc-activity)*
    - **Firma 5:** ET INFO EXE IsDebuggerPresent (Used in Malware Anti-Debugging) *(SID: 2015744 / Clase: misc-activity)*
    - Evidencia de Respuesta del Servidor (Descarga de /kartos/krt.exe):

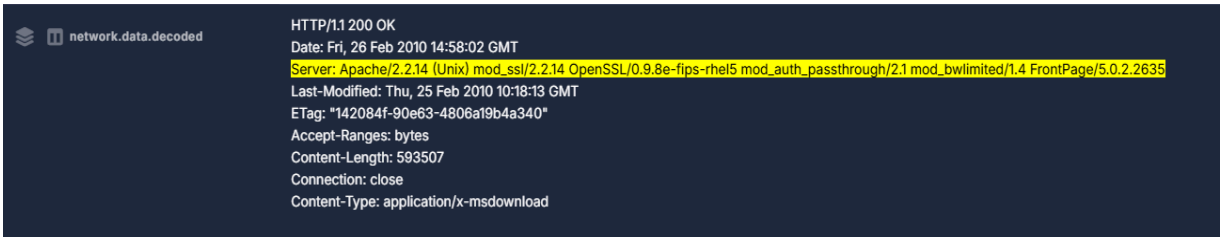


- **Fase C: Solicitud y transferencia del segundo ejecutable**
    - **Explicación:** En paralelo a la acción anterior, el dispositivo interno genera una nueva sesión web para descargar el archivo /ser.exe. En esta transacción, el malware altera el destino lógico de la cabecera *Host* apuntando al dominio simulado www[.]hostme[.]name. El servidor responde con un estado 200 OK transfiriendo un archivo de gran tamaño (593,507 bytes). El escaneo automatizado del motor perimetral analizó el flujo binario completo en

tránsito y determinó mediante firmas que se trata del componente ejecutable principal (Payload), identificándolo de forma específica como un Troyano.

- **Firma IDS 1:** ET MALWARE Terse alphanumeric executable downloader high likelihood of being hostile *(SID: 2019714 / Clase: bad-unknown / Severidad: 2)*
- **Firma IDS 2**: ET INFO PE EXE or DLL Windows file download HTTP *(SID: 2018959 / Clase: policy-violation / Severidad: 1)*
- Evidencia de petición y respuesta correlacionada (Descarga de /ser.exe):





- **Fase D: Actividad de comando y control (C2) y beaconing**
  - **Explicación Técnica:** Los registros confirman que la comunicación hacia el servidor de comando y control (C2) se ejecutó de manera concurrente durante el ciclo de descargas. El host interno transmitió paquetes salientes utilizando el método POST contra el script /kartos/youyou.php. El primer envío ocurrió en paralelo a las descargas (a las 19:01:58.153) transmitiendo una carga útil de **271 bytes**. Una segunda transmisión ocurrió al finalizar la secuencia (a las 19:01:58.700) enviando **169 bytes**. Esta actividad de balizamiento (*beaconing*) representa el canal mediante el cual el equipo comprometido reporta parámetros básicos de control y estado técnico hacia el atacante.
  - **Firma IDS:** ET MALWARE Zbot POST Request to C2 *(SID: 2019141 / Clase: command-and-control / Severidad: 1)*
  - Evidencia de Carga Útil en Petición POST (Tráfico Saliente hacia /kartos/youyou.php):



2. Matriz de Indicadores de Compromiso (IoCs) extraídos

Tipo de IoC	Valor técnico detectado	Descripción y contexto en red
Dirección IPv4 (C2)	188[.]72[.]243[.]72	Servidor externo malicioso (Webzilla B.V. - Países Bajos).
Dominios de destino	ishi-bati[.]com www[.]hostme[.]name	Direcciones mapeadas en las cabeceras *Host* de las transacciones HTTP de forma alternada.
Rutas de recursos (URIs)	/kartos/kartos.bin /kartos/krt.exe /ser.exe /kartos/youyou.php	Archivos de configuración binaria, ejecutables de descarga y scripts PHP de beaconing C2.
Navegador falsificado	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; SV1)	Parámetro *User-Agent* artificial inyectado para simular entornos Windows XP obsoletos.
Hash SHA256 (krt.exe “krt-ETG.exe”**)**	68a7f7bd5627c5cc465373983acf21958746c12e3441cccd1dfbc234944b8cf2	Huella digital de red del componente empaquetado inicial. Veredicto de motor antivirus perimetral: VIRUS Mal/Resdro-A.
Hash SHA256 (ser.exe “Stub.exe”**)**	282f463d7cdec977d675231279365dd890f1480dafa9d88473d5d47574e007b0	Huella digital de red del componente troyano principal. Veredicto del : VIRUS Troj/VB-KVA.

Conclusión: Los sistemas internos y activos de infraestructura propios de Technoma se encuentran totalmente fuera de peligro y libres de intrusiones. A nivel corporativo, el incidente está contenido. Sin embargo, los registros demuestran de manera concluyente que la máquina interna del cliente (**192.168.3.65**) presenta un estado de compromiso activo, compatible con un troyano con capacidades de inyección en memoria y beaconing hacia servidores C2. La red perimetral confirmó la transferencia completa de los componentes en la capa de transporte y el posterior inicio de las transmisiones salientes (POST). Debido a que las cabeceras HTTP registran parámetros de terminación forzada (Connection: close), los canales de descarga individuales se cerraron inmediatamente después de la entrega de datos, por lo que se requiere una auditoría interna directa en el propio endpoint del cliente para confirmar el estado final de almacenamiento o ejecución local de los archivos.